

7.15 release Stack 01 audit — local candidate

The local source review and preflight are complete. Hosted final-head review, Stack 00b predecessor acceptance and physical release checks remain pending.

Identity and scope

- Owner: Codex /root, keepkey-vault-v11-agent-2; main-worktree claim: docs/release/audit-claims/715-01/OWNER.md.
- Main-worktree master form SHA256 at intake: 0821e9ea94225ff6332a9ce55ac32eb518277eaf0dc50cd2ba3c1f36be0aa131.
- Isolated worktree: /private/tmp/kk-715-stack01-audit, branch audit/715-stack01-review.
- Code-bearing [PR #831](#): release/715-stack-01-evm at 66ca726662822a9ff102bcd1354cc6a39d5a203b against immediate predecessor release/715-stack-00b-release-foundation at 4c56e19e3070772a28b2890a4ec862ecf77d5429 when claimed.
- The adjacent diff is 80 paths, 3,017 added and 663 deleted lines, from `git diff --numstat 4c56e19e3070772a28b2890a4ec862ecf77d5429..66ca726662822a9ff102bcd1354cc6a39d5a203b`. It changes firmware, tests, CI, build inputs and documentation; the PR is code-bearing. The one commit in the range is 66ca72666.
- Stack 00b is separately claimed and has no completed checkpoint in the canonical ledger. Stack 01 cannot be called accepted on predecessor ancestry until that claim completes and its head is reconciled.
- Audit remediation commits: cbc725dc6 restores the emulator animation; 692543774 adds its board regression; 199e491e9 narrows auto-lock activity to validated workflow continuation responses and replaces direct helper tests with transport tests. 5e0151438 and 4f3daef30 are report intake edits. The containing final report head is recorded in the PR body.

Frozen dependency pins and original line inventory

The predecessor and original Stack 01 head have identical top-level gitlinks:

Dependency	Exact commit
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c
deps/device-protocol	dd9c85dc747cf965fb0e7bf49615dc9e7568ee65
deps/python-keepkey	49d537ce953b7524599bfc87f56b7a50a51a13a1
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

The Python host's nested device-protocol is at dd9c85dc and ethereum-lists at 89a64f717e1690bb31adb3e4c38e23640357333c. code-signing-keys is at a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec. No gitlink changes occur in this block; the .gitmodules line is whitespace only. The untouched nested crypto test/vendor gitlinks were not initialized locally and are not inputs to the cited native build.

The original unit has one commit, 66ca726662822a9ff102bcd1354cc6a39d5a203b. Its complete per-path counts below come from the immutable command `git show --format= --numstat --no-renames 66ca726662822a9ff102bcd1354cc6a39d5a203b`. The counts include implementation, tests, workflows, scripts, build files and documentation; they are the original adjacent diff, not a sum of later audit remediation commits. The changed-path descriptions are grouped here to keep the per-path table readable:

- **Build, protocol and CI:** CMake now includes Zcash privacy in the regular image and keeps Bitcoin only reduced, links the needed Pallas and metadata objects, and checks native XML inputs. CI retries external pulls and caches cppcheck and images, while its final gate still depends on static analysis. The release instructions now match each binary against its own manifest. Full and Bitcoin-only hosted jobs passed at the original head.
- **Dice and setup:** The reset ceremony now stages settings until a seed is committed, offers two explicit dice modes with on-device consent, shows the device draw for offline verification in mixed mode, rejects biased rolls, and pages all backup words. The verifier reproduces the firmware tags and BIP-39 conversion. Host dice capture and unit cases check cancellation, derivation, settings and output. Physical display and power interruption remain release checks.
- **Session and secret lifetime:** Transport, tiny acknowledgements, PIN and passphrase buffers, RNG output, storage reads and CRC, recovery word count, and signing context receive targeted bounds, cleanup and fail-closed fixes. The local S01-01/S01-02 patches address the auto-lock policy and emulator host-wait animation found during this review.

- **Chain behavior:** Wanchain transfer formatting uses the current request; THOR/MAYA deposit memo narration, MAYA decimals, Ripple response lifetime and unsupported memo rejection, Bitcoin input comparison, and Zcash build coverage have corresponding native cases. Message-map entries were compared as parsed tuples: all 140 base entries equal all 140 head entries in order; its 411 changed lines are formatting and equivalent conditional spelling.
- **Prior audit notes:** The added historical P-unit notes and previous combined-candidate documents explain source provenance; they do not turn their receipt-only review PRs into firmware-code coverage. This block's code-bearing adjacent diff supplies the current review surface.

Original commit path counts

Added	Deleted	Path
65	15	.github/workflows/ci.yml
24	2	.github/workflows/release.yml
1	1	.gitmodules
16	4	CMakeLists.txt
1	0	deps/crypto/CMakeLists.txt
141	39	docs/DiceEntropy.md
154	0	docs/dice-vs-coldcard.md
78	0	docs/firmware/reviews/7.15.0-review-round2-remediation.md
83	31	docs/release/7.14.3-COMBINED-CANDIDATE.md
12	0	docs/release/audit-units/P01-004-report-inputs.md
16	0	docs/release/audit-units/P01-008-compose-variant.md
27	0	docs/release/audit-units/P02-001-tiny-lifetime.md
14	0	docs/release/audit-units/P02-003-packet-lifetime.md
18	0	docs/release/audit-units/P06-002-ripple-display-response.md
15	0	docs/release/audit-units/P06-003-ripple-display-test.md
21	0	docs/release/audit-units/P06-005-ripple-unsupported-memo.md
12	0	docs/release/audit-units/P06-006-ripple-memo-rejection-test.md
87	0	docs/release/audit-units/full-diff-audit-20260912.md
32	0	docs/release/audit-units/scope-repair.md
12	1	docs/security/7.14.3-bitcoin-only-dice-audit-sop.md
3	0	include/keepkey/board/layout.h
3	0	include/keepkey/board/messages.h
26	3	include/keepkey/firmware/dice_input.h
7	10	include/keepkey/firmware/ethereum_contracts/thortx.h
1	0	include/keepkey/firmware/fsm.h
2	0	include/keepkey/firmware/home_sm.h
1	0	include/keepkey/firmware/mayachain.h
14	12	include/keepkey/firmware/reset.h
8	2	include/keepkey/firmware/ripple.h
1	1	include/keepkey/firmware/tiny-json.h
2	1	include/keepkey/firmware/txin_check.h
8	1	lib/board/confirm_sm.c
13	10	lib/board/keepkey_board.c
4	2	lib/board/keepkey_flash.c
4	3	lib/board/layout.c
38	10	lib/board/messages.c
2	5	lib/board/udp.c
15	3	lib/board/usb.c
6	0	lib/firmware/CMakeLists.txt
131	70	lib/firmware/dice_input.c
11	0	lib/firmware/ethereum.c
3	2	lib/firmware/ethereum_contracts/thortx.c
52	16	lib/firmware/fsm.c
23	7	lib/firmware/fsm_msg_common.h
12	4	lib/firmware/fsm_msg_ripple.h
37	1	lib/firmware/home_sm.c
16	1	lib/firmware/mayachain.c
245	166	lib/firmware/messagemap.def
1	0	lib/firmware/passphrase_sm.c
20	8	lib/firmware/pin_sm.c
22	2	lib/firmware/recovery_cipher.c
232	130	lib/firmware/reset.c
1	1	lib/firmware/ripple.c
15	6	lib/firmware/signing.c
32	11	lib/firmware/storage.c
2	2	lib/firmware/transaction.c
6	4	lib/firmware/txin_check.c
11	0	lib/rand/rng_health.c
19	9	scripts/emulator/capture-dice-flow.py
1	0	scripts/emulator/docker-compose.bitcoin-only.yml
21	2	scripts/generate-test-report.py
1	1	tools/firmware/keepkey.ld
251	0	tools/verify_dice_seed.py
46	0	unittests/board/board.cpp
1	0	unittests/firmware/CMakeLists.txt
33	0	unittests/firmware/confirm_test_utils.cpp
78	26	unittests/firmware/dice.cpp
242	0	unittests/firmware/fsm.cpp

```

19    0 unittests/firmware/mayachain.cpp
46    0 unittests/firmware/recovery.cpp
20    0 unittests/firmware/ripple.cpp
25    0 unittests/firmware/rng_health.cpp
15    9 unittests/firmware/setup_ceremony.cpp
21   22 unittests/firmware/signed_metadata.cpp
48    0 unittests/firmware/signing.cpp
33    1 unittests/firmware/storage.cpp
26    0 unittests/firmware/storage_passphrase.cpp
102   0 unittests/firmware/transaction.cpp
95    0 unittests/firmware/usb_rx.cpp
15    6 unittests/firmware/zcash.cpp

```

Evidence checked

- `git diff --check` on the frozen range passed.
- Exact-head nonpublishing [CI run 35685552039](#) succeeded: format, secret scan, static analysis, submodule check, full and Bitcoin-only ARM builds and SRAM gates, emulator builds, unit and Python integration suites, dylib tests, report generation, evidence and CI gates. `publish-emulator` was skipped as intended. A concurrent run 35685552437 at the same SHA was cancelled; it is not the success receipt.
- Original run artifacts include full and Bitcoin-only ARM bundles 10677175575 and 10676522831, test report 10677076880, full and Bitcoin-only native results 10676681571 and 10676557872, Python results 10676921425 and 10676557869, and OLED captures 10676691543 and 10676338173. The two emulator-image artifacts have expired; all these artifacts refer to the original PR head, not the local remediation.
- Source inspection covered reset/dice derivation and pager, transport rejection and tiny replies, USB buffer cleanup, FSM session policy, storage CRC, signing input comparison, Ripple, MAYAChain, the message map and CI wiring. The complete original changed-path ledger and dependency pin reconciliation are above. Physical display review remains a release gate.
- The local emulator fix and its focused `BodyFits.EmulatorPollAdvancesHostWaitProgress` regression passed in the SOP Docker `firmware-unit` compose run on 2026-09-23: 327 firmware, 20 board and 18 crypto tests passed. The first local build attempt stopped before compilation because the nested pinned `ethereum-lists` submodule was absent; after initializing it at 89a64f71, the same command completed with exit code 0. The Bitcoin-only compose run also passed: 114 firmware, 20 board and 18 crypto tests. The local fix commits are `cbc725dc6` (pump) and `692543774` (regression); these are not in PR #831's green hosted run.

Findings and policy disposition

S01-01 — unrelated host traffic extends an active session's auto-lock

Severity: P2 policy/security review, fixed locally after owner decision. Changed lines: `lib/firmware/fsm.c:328–330` and `lib/firmware/home_sm.c:193–197` at the PR head. `fsm_usb_rx()` calls `note_host_activity()` before parsing or dispatching every frame. While `home_state == AWAY_FROM_HOME`, that clears the idle timer regardless of message type, validity or whether it advances the signing/setup workflow. A host that periodically sends `GetFeatures` (or malformed frames) can keep an otherwise stalled signing session from reaching the configured auto-lock delay. The new tests in `unittests/firmware/fsm.cpp` call `note_host_activity()` directly and prove only that any call extends the timer; they do not exercise unrelated frames through USB or set a policy for them. The same concern was recorded in the 2026-09-13 re-audit handoff for the candidate line. On 2026-09-23 the owner specified that only active workflow progress should extend the timer. The local patch removes the pre-dispatch reset and calls `note_host_activity()` after a continuation request is encoded and sent. It names the supported streamed request types; `Features`, `failures`, and other unrelated responses are excluded. The new regression sends a valid `GetFeatures` packet through the parser during a Bitcoin signing wait and proves auto-lock still fires, while a sent `TxRequest` extends the wait. These tests passed in a full local Docker native run: 328 firmware, 20 board, 18 crypto tests. A compose up first failed before tests because local port 5000 was occupied; `docker compose run --no-deps firmware-unit` on the same built image completed with exit code 0. The original exact-head hosted CI predates this patch. The Bitcoin-only image built separately with `docker-compose.bitcoin-only.yml`, then its native run also passed: 115 firmware, 20 board, 18 crypto tests.

S01-02 — emulator progress animation stopped while polling the host

Severity: P3, fixed locally in this audit branch. The PR replaced the tail of `lib/board/udp.c:usbPoll()` with a buffer scrub and removed its call to `layout_animate_poll()`. The hardware USB poll still calls the animation pump; without the emulator call, a queued Zcash progress animation freezes whenever the emulator is waiting for host proof generation. The local patch restores the animation call after the buffer scrub. A new board test arms the real progress trickle, calls `emulator_usbPoll()`, and requires a display refresh; it passed in the local Docker run above. Physical Zcash signing is still a release gate.

Current-source reconciliation

Surface	Current source and disposition	Evidence or limit
Session auto-lock	S01-01 fixed locally: only sent continuation requests reset the timer while away from home.	Full and Bitcoin-only native regression through GetFeatures RX and TxRequest TX passed. Hosted final-head checks pending.
Emulator host-wait progress	S01-02 fixed locally: <code>usbPoll()</code> scrubs its buffer and pumps <code>layout_animate_poll()</code> .	Board regression passed in both variants. Physical Zcash proof wait remains unverified.
Setup/dice derivation	<code>reset_init()</code> stages settings, commits only after backup review, and derives dice modes from recorded inputs. Firmware and offline verifier tags and SHA order match.	Native setup/dice cases and original hosted Python integration passed; physical OLED paging and power-cycle remain release gates.
Transport/secret lifetime	Tiny rejection unwinds once, clears buffers; raw RX and response arena lifetimes are bounded; new RNG draw recheck and V17 CRC alignment are in source.	Native unit coverage and original hosted ARM/ SRAM pass. The test's emulator CRC matches the STM32 word recurrence.
Bitcoin signing	The current input digest is finalized from a copy; a refused output does not replace the prior comparison key; multisig sighash scratch has one extra byte.	Native signing/transaction cases passed. Physical signing remains a release gate.
Chain UX	Wanchain ticker uses current transaction type; THOR/MAYA raw memo and MAYA.CACAO scaling are present; Ripple rejects unsupported nonempty memos and copies the confirmed address after shared response arena use.	Native chain cases and original hosted integration passed. Router addresses remain externally maintained trust pins.
Storage power interruption	Inherited erase-before-replacement risk remains in this candidate.	Not fixed by Stack 01; signed-device power-cut and upgrade checks are still required before release.

No dependency pointer changed in the adjacent Stack 01 diff. The firmware source is on the code-bearing PR, while prior P02/ P06 receipts on documentation PRs are historical evidence only. No physical device or signed image was used for this unit review.

Code-bearing review coverage

Claimed behavior	PR #831 code/test paths in the adjacent diff
Auto-lock counts workflow progress (S01-01)	<code>lib/firmware/fsm.c</code> , <code>lib/firmware/home_sm.c</code> , <code>lib/board/usb.c</code> , <code>include/keepkey/board/messages.h</code> , <code>unittests/firmware/fsm.cpp</code>
Emulator host-wait animation (S01-02)	<code>lib/board/udp.c</code> , <code>unittests/board/board.cpp</code>
Dice and staged setup	<code>lib/firmware/reset.c</code> , <code>lib/firmware/dice_input.c</code> , <code>tools/verify_dice_seed.py</code> , <code>unittests/firmware/dice.cpp</code> , <code>unittests/firmware/setup_ceremony.cpp</code>
Storage and transport lifetime	<code>lib/firmware/storage.c</code> , <code>lib/board/messages.c</code> , <code>lib/board/usb.c</code> , <code>lib/firmware/recovery_cipher.c</code> , <code>unittests/firmware/storage.cpp</code> , <code>unittests/firmware/usb_rx.cpp</code>
Signing and chain display	<code>lib/firmware/signing.c</code> , <code>lib/firmware/transaction.c</code> , <code>lib/firmware/txin_check.c</code> , <code>lib/firmware/ethereum.c</code> , <code>lib/firmware/fsm_msg_ripple.h</code> , <code>lib/firmware/mayachain.c</code> , corresponding native tests
Variant and evidence gates	<code>CMakeLists.txt</code> , <code>lib/firmware/CMakeLists.txt</code> , <code>.github/workflows/ci.yml</code> , <code>scripts/generate-test-report.py</code> , <code>tools/firmware/keepkey.ld</code>

The late reviewer must be given the final base-to-head diff for these paths; a review of this report alone would assess only the receipt.

Verification matrix and limits

Check	Exact source	Result	Limit
Original full CI	66ca726662822a9ff102bcd1354cc6a39d5a203b, run 35685552039	Green required graph: ARM/SRAM, emulator, native, Python, dylib, static, lint, report and CI gate.	Predates audit fixes; emulator publication skipped.
Original concurrent CI	same SHA, run 35685552437	Cancelled.	Not a success receipt.
Full local native	audit code through 199e491e9	328 firmware, 20 board, 18 crypto passed.	Docker AMD64 under ARM host; native emulator tests, no physical device.
Bitcoin-only local native	audit code through 199e491e9	115 firmware, 20 board, 18 crypto passed.	Same host limit.
Full local host/emulator	audit code through 199e491e9	Docker Python suite exited 0: 568 passed, 262 skipped; OLED-required capture pass ran first.	Uses the same missing-capability list as original CI. Skip set includes still-unshipped release capabilities; no physical OLED.
Local report input gate	audit code through 199e491e9	<code>require_native_junit()</code> accepted the three extracted nonempty, parseable JUnit suites: <code>firmware.xml</code> , <code>board.xml</code> , <code>crypto.xml</code> .	This exercises the changed native-input gate, not the full report assembly, which also needs CI ARM and dylib artifacts.
Original diff whitespace	4c56e19e..66ca7266	<code>git diff --check</code> passed.	Will rerun on final range.
Message map parity	original predecessor and head	All 140 parsed entries equal in order.	Does not prove handler semantics by itself.

The original CI ARM bundles still bear the staging filename `v7.14.3`; that filename does not establish a 7.15 signed release artifact. The local code patch has no new dependency or workflow changes. A green CI run on the pushed final code-bearing head is required before a unit checkpoint.

Checkpoint status

- Internal source and interaction review: complete on the local candidate; S01-01 and S01-02 are fixed and exercised in both variants. The inherited storage power-interruption risk is unchanged and remains a release blocker.
- Exact-head hosted CI: pending until the report and code head are pushed.
- Stack 00b: separately claimed, not yet accepted; reconcile its final head and PR #831's base before accepting Stack 01.
- Late code-bearing Copilot checkpoint: not requested yet. This report and its PDF must be frozen and preflighted first; review must cover PR #831's code paths on its current base and head.
- Assembled 7.15 product and physical release: pending signed-device upgrade, power-interruption, signing, Zcash wait and OLED checks. No production promotion or publication is implied by this unit audit.